

РАЗРАБОТКА ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ ДЛЯ АНАЛИЗА ЗАЩИЩЁННОСТИ ИНФОРМАЦИОННЫХ СИСТЕМ НА ОСНОВЕ СЦЕНАРИЕВ КОМПЬЮТЕРНЫХ АТАК

С.С. Куликов, Н.Н. Мурзинов

В данной статье представлено описание принципов построения и функционирования, а также некоторые архитектурные особенности специального программного обеспечения, которое может использоваться для анализа защищённости информационных систем на основе базы данных паттернов (шаблонов) компьютерных атак, характерных для определенных типов нарушителей и их групп. Задача анализа защищённости является важным этапом работ по защите информации как при формировании требований по защите информации, так и при оценке эффективности уже реализованных мер. Ввиду нетривиального, а в какой-то мере и даже творческого характера, решение данной задачи требует высокой квалификации от специалиста, значимых временных и материальных затрат. Вследствие этого возникает объективная задача по автоматизации такой деятельности. В работе описана попытка решения указанной задачи на основе разработки программного обеспечения, использующего данные из открытых источников, обобщающих опыт и квалификацию специалистов информационной безопасности из разных стран.

Ключевые слова: анализ защищённости, информационная система, открытые данные.

Введение

В условиях современности, при которых информация – ключевой ресурс, подавляющее большинство межгосударственных, корпоративных и даже общественных конфликтов перетекло в информационную сферу, выбрав в качестве «поля боя» арену сетевого противоборства и соответствующую ей технологическую инфраструктуру.

Это подтверждают события, широко освещаемые в средствах массовой информации. В 2013 года «хакерская группировка» «APT1», ассоциированная с властями КНР, нарушила конфиденциальность персональных данных пользователей 40 американских IT-компаний, включая «Facebook», «Twitter» и «Apple». В мае 2021 года группа «DarkSide» парализовала работу трубопроводной системы «Colonial Pipeline», где в результате нарушения целостности служебных данных помимо прямого ущерба инфраструктуре был нанесен и косвенный, – в виде последствий кризиса на американском топливном рынке, которые количественно превзошли последствия прямого ущерба. И, несомненно, это и регулярные попытки манипулировать общественным мнением ради

достижения политических, экономических и террористических целей [1].

Проведение случайных или таргетированных атак в отношении информационной инфраструктуры возможно вследствие множества причин: из-за наличия уязвимостей в применяемом программном обеспечении, недостатков архитектуры информационной инфраструктуры, ошибок при проектировании и внедрении системы защиты информации и др.

С целью обеспечения безопасности информации и повышения защищённости информационных систем, информационно-телекоммуникационных сетей и автоматизированных систем управления, в частности тех, которые являются значимыми объектами критической информационной инфраструктуры, государственными или муниципальными информационными системами, а также информационными системами персональных данных, уполномоченными федеральными органами исполнительной власти разработан целый комплекс требований, рекомендаций, информационных ресурсов и программного обеспечения [2].

Например, для обнаружения и устранения уязвимостей в программном обеспечении в открытом доступе находится Банк данных угроз и уязвимостей ФСТЭК России, а также общедоступное средство ScanOVAL. Недостатки, связанные с применяемыми в объекте защиты информационными технологиями должны учитывать при формировании модели угроз безопасности информации и нивелироваться путем применения соответствующих средств защиты информации при проектировании системы защиты информации.

Однако, данные действия, несмотря на их безусловную необходимость, не в полной мере позволяют учесть все внешние факторы, связанные с потенциалом и характерными особенностями действий самих нарушителей или их групп, оказать влияние на которые возможность отсутствует. Подобный подход нашел свое отражение в документах регуляторов только в 2021 году, в виде методического документа «Методика оценки угроз безопасности информации».

Таким образом, анализ векторов компьютерных атак является перспективным направлением анализа защищенности информационных систем.

Постановка задач работы

Основной целью данной работы следует считать разработку специального программного обеспечения, которое может использоваться для анализа защищенности информационных систем на основе базы данных паттернов (шаблонов) компьютерных атак с учетом имеющейся информации о действиях известных групп нарушителей.

Для достижения поставленной цели необходимо решение следующих задач:

- определить механизм формирования базы данных паттернов (шаблонов) компьютерных атак;
- разработать алгоритм анализа защищенности информационных систем на основе базы данных паттернов (шаблонов) компьютерных атак;
- разработать программное обеспечение, автоматизирующее процесс анализа защищенности информационных систем.

Формирование базы данных паттернов компьютерных атак

На сегодняшний день процесс обеспечения безопасности информации уходит от противодействия локальным или внутренним атакам в сторону защиты от типовых атак, которым подвержены информационные системы вне зависимости от их территориального расположения или юрисдикции. Соответственно, наиболее рациональным подходом для предупреждения подобных компьютерных атак является консолидация квалификации, опыта и результатов исследований специалистов по информационной безопасности из разных стран.

Данный подход используется в «Open Source» (открытый источник) проектах, например, таких как сайт GitHub, предоставляющий эффективные и удобные инструменты для совместной разработки. Применительно к проблемной сфере это проекты Cyber Kill Chain, Diamond Model и MITRE ATT&CK. Последний содержит матричное описание тактик и техник реализации компьютерных атак. Тактики – это конкретные практические задачи, которые решает нарушитель для успешной реализации определенной компьютерной атаки, а техники – это то, каким именно образом нарушитель непосредственно решает эти задачи, какие инструменты, технологии и программный код использует. Причины выбора именно этого ресурса в качестве основного источника данных для анализа оставим вне настоящей статьи.

Прикладными направлениями применения в разрабатываемом приложении MITRE ATT&CK являются:

1. Возможность идентификации нарушителя по имеющимся признакам использованных техник компьютерных атак.
2. Автоматизации выявления уязвимостей информационной системы за счет проверки реализуемости известных техник компьютерных атак.
3. Автоматизация определения актуальных угроз безопасности информации за счет построения так называемых цепочек атаки (англ. «kill-chain»).

4. Расследование совершенных компьютерных атак.

Для удобства специалиста по информационной безопасности, в частности для снижения требований к его квалификации, предлагается предварительно по открытым данным сформировать паттерны (шаблоны) компьютерных атак, характерные для известных групп нарушителей («хакерских группировок»), выбор которых позволит освободить пользователя от формирования цепочек атак. Эта задача была решена для групп нарушителей, известных под названиями «Higaisa», «Goblin Panda», «Winnti», «DarkSide», «APT32» [3]. Пример описания для первой из них представлен в табл. 1.

Важной задачей является выстраивание и формализация связи между данными об известных тактиках и техниках компьютерных атак, программным кодом, проверяющим их реализуемость, а также аналитическими выводами о состоянии защищённости информационных систем.

Разработка алгоритма анализа защищённости информационных систем

Алгоритм анализа защищённости разработан на основе модели, в которой присутствует информационная система с определённой уязвимостью. Извне нарушителем формируется и реализуется угроза.

Учитывая структурные, функциональные и иные особенности исследуемого объекта защиты пользователю должна быть предоставлена возможность выбрать готовые сценарии реализации компьютерных атак или сформировать их самостоятельно, если требуется их адаптация.

Непосредственно проверка каждого этапа одного сценария может быть осуществлена с помощью юнит-тестов. Связанная с MITRE ATT&CK библиотека Atomic Red Team содержит исходный код таких тестов для проверки реализуемости тактик и техник компьютерных атак в условиях конкретной информационной системы.

Проверка каждого этапа сценария завершается бинарным результатом, -

успешно (техника реализуема) и неуспешно (техника не реализуема).

Таблица 1

Пример техник компьютерных атак, используемых группой нарушителей, известной под именем «Higaisa»

№ п/п	Номер и название техники	Описание техники
1	T1566.001 Фишинг	Нарушители с помощью спам бота доставляют письма с вредоносными вложениями
2	T1059.003 Запуск вредоносных «power shell»-скриптов	Нарушители используют утилиту «cmd.exe» для запуска вложенной полезной нагрузки
3	T1059.005 Использование «Visual Basic»-скрипты	Использование «VBS»-скриптов
4	T1059.007 Использование языка программирования «JavaScript»	Нарушители используют «JS»-скрипты для взлома web-приложений
5	T1543.003 Создание или изменение системного процесса службы «Windows»	Нарушители используют сервисы операционной системы для закрепления в системе
6	T1137.006 Запуск надстроек в приложениях «Microsoft Office»	Нарушители используют билдер «RoyalRoad», чтобы извлечь в папку с плагинами для «Microsoft Word» заражённый файл «intel.wll»
7	T1547.001 Выполнение автозапуска при загрузке или входе в систему	Нарушители проникают в операционную систему через реестр или папку с именем «STARTUP» и затем закрепляются в ней
8	T1574.002 Перехват процесса исполнения программ	Нарушители используют легитимные исполняемые файлы совместно с вредоносными dll-библиотеками

Учитывая нелинейность сценария неуспешный результат не означает невозможность реализации всего сценария, поэтому итоговый результат основывается на

сочетании техник компьютерных атак в рамках одной тактики, то есть, фактически, одного этапа сценария реализации атаки.

Итоговый результат анализа защищенности на текущий момент также бинарен, – успешно (сценарий реализуем) и неуспешно (сценарий не реализуем) (рис. 1). Однако существует возможность перехода к вероятностным характеристикам, например, с помощью математического аппарата марковских цепей.

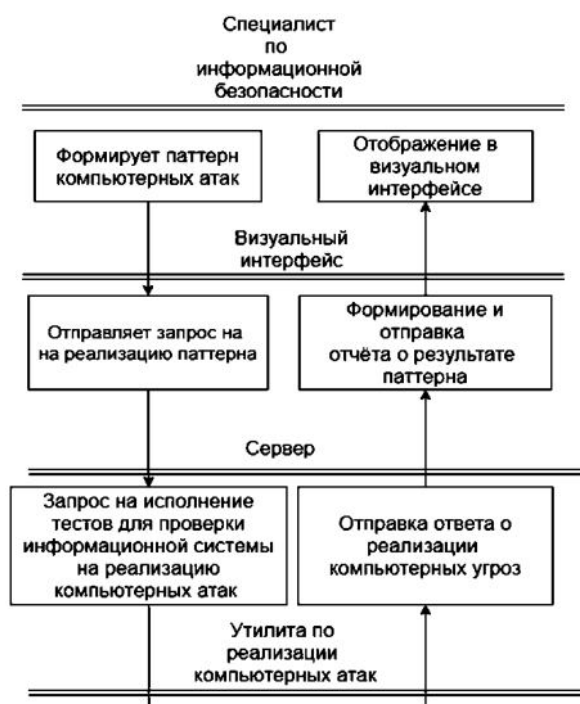


Рис. 1. Схема алгоритма анализа защищенности информационных систем

Разработка программного обеспечения для анализа защищенности информационных систем

Для построение визуальной составляющей приложения был выбран JavaScript-фреймворк с открытым исходным кодом – AngularJS. Он позволяет с помощью языка разметки html и таблицы стилей css создать удобный интерфейс для создания паттернов. Среди основных компонентов можно выделить компонент поиска необходимых техник, компонент паттерна, табы для переключения между различными компонентами.

Серверная часть использует фреймворк на основе языка программирования java – spring, в частности основанный на spring boot,

который содержит web-комплент, способный обрабатывать http-запросы. С их помощью непосредственно происходит клиент северное взаимодействие.

Серверная часть, представляет собой REST-приложение. Оно состоит из разных классов которые можно разделить на три группы:

1. Клиент – класс, который может принимать и отправлять HTTP-запросы, основан на такой технологии как сервлеты.

2. Сервисы – классы, отвечающие за логику приложения. В них происходит вызов утилиты по исполнению тестов, обработка результатов.

3. Репозитории – классы, отвечающие за взаимодействие с базой данных.

Как уже отмечалось выше, Atomic Red Team – библиотека, с помощью которой будут проводиться юнит-тесты, представленные в виде cvs-файлов. В таком файле описаны все возможные тактики и техники. Для удобства пользования и обеспечения производительности было принято решение загрузить весь этот файла в базу данных postgresql.

Графический пользовательский интерфейс состоит из двух страниц, вид одной из которых представлен на рис. 2.

Графическими элементами управления, представленными на рис. 2, являются: 1 – поле ввода имени паттерна; 2 – поле выбора техники по её номеру; 3 – окно вывода соответствующих техник для последующего выбора; 4 – кнопка для инициализации процесса создания нового паттерна; 5 – перечень выбранных для добавления в паттерн техник; 6 – список операционных систем для тестирования.

Результат анализа паттерна представляется в виде перечня тактик, подсвеченных в зависимости от результата проверки: зелёный – означает, что удалось защититься от техники; красный – не удалось защититься от техники; жёлтый – техника не может быть проверена на данном устройстве.

Разработанное программное обеспечение официально зарегистрировано в системе Роспатента.

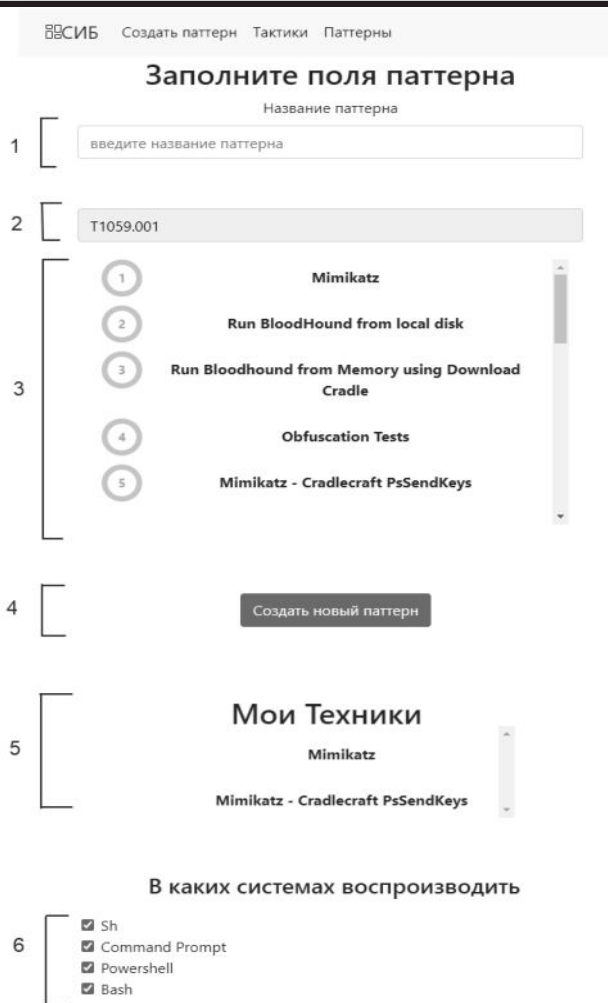


Рис. 2. Интерфейс приложения

Заключение и перспективы работы

В результате проведенной работы:

- матрица MITRE ATT&CK выбрана как основной источник данных для формирования паттернов компьютерных атак, в том числе характерных для известных групп нарушителей;

- алгоритм анализа защищенности информационных систем на основе базы данных предустановленных и формируемых самостоятельно паттернов (шаблонов) компьютерных атак;

- программное обеспечение, автоматизирующее процесс анализа защищенности информационных систем.

Теоретическая ценность полученных результатов заключается в том, что:

- разработанный алгоритм достаточно универсален и может использоваться с другими базами данных, библиотеками и фреймворками в сфере информационной безопасности;

- используемый алгоритм анализа защищенности имеет ясную перспективу улучшения путем применения технологий анализа больших данных, в том числе методов искусственного интеллекта [4];

- разработанный алгоритм может быть усовершенствован в направлении получения вероятностных оценок защищенности информационных систем, например, с помощью математического аппарата марковских процессов.

Практическая ценность результатов работы видится в том, что:

- применение разработанного программного обеспечения позволяет снизить требования к исходной квалификации специалиста по информационной безопасности как к пользователю средств данного класса, а также существенно снижает трудозатраты;

- разработанное программное обеспечение может использоваться для выработки рекомендаций по устранению уязвимостей и настройке средств защиты информации [5];

- разработанное программное обеспечение позволит визуализировать процесс анализа защищенности информационных систем, что может быть использовано в подготовке специалистов, обеспечивающих информационную безопасность.

Однако, наряду с очевидным положительным эффектом от результатов работы, существуют и существенные ограничения на их применение:

- информационное наполнение используемых баз данных на текущий момент является неполным и не позволяет проанализировать абсолютно все техники компьютерных атак;

- информационное наполнение используемых баз данных формируется профессиональным сообществом, но может содержать некорректную информацию, что приведет к ложным результатам анализа защищенности информационных систем;

- разработанное программное обеспечение использует открытые данные и сможет пройти процедуру сертификации по требованиям безопасности информации,

следовательно не может быть использовано как средство защиты информации в случае предъявления таких требований.

Список литературы

1. Остапенко, А.Г. Основы метрологии контентов для мониторинга социальных сетей на предмет обеспечения информационной безопасности. Часть 1. / А.Г. Остапенко, Е.С. Соколова, А.В. Ещенко, А.А. Остапенко, Т.Ю. Чапурина. // Информация и безопасность. 2019. Т. 22. Вып. 2. С. 170-180.

2. Калашников А.О. Влияние новых технологий на информационную безопасность критической информационной инфраструктуры [Текст] / А.О. Калашников, Е.В. Аникина, Г.А. Остапенко и др. // Информация и безопасность. – 2019. – Т. 22. – Вып. 2. – С. 156-169.

3. Информация по хакерским группировкам [Электронный ресурс] URL: <https://www.ptsecurity.com/ru-ru/research/hacker-groups/higaisa/> (дата обращения: 20.09.2021).

4. Остапенко, Г.А. Возможности использования систем искусственного интеллекта и больших данных при реализации риск-мониторинга регионального социо-информационного пространства. / Г.А. Остапенко, Е.А. Москалева, Е.Ю. Чапурин и др. // Информация и безопасность. 2019. Т. 22. Вып. 4. С. 587-600.

5. Филяк, П.Ю. Автоматизация управления доступом с помощью моделей анализа систем защиты. / П.Ю. Филяк, В.В. Растворов, С.С. Куликов, В.И. Белоножкин, М.И. Бочаров. // Информация и безопасность. 2019. Т. 22. Вып. 2. С. 214-219.

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 21.09.2021

Информация об авторах

Куликов Сергей Сергеевич – канд. техн. наук, доцент, Воронежский государственный технический университет, e-mail: kulikov.serg@yandex.ru

Мурзинов Николай Николаевич – студент, Воронежский государственный технический университет, e-mail: murzinov.nikolay@yandex.ru

DEVELOPMENT OF SOFTWARE TO ANALYZE THE SECURITY OF INFORMATION SYSTEMS BASED ON COMPUTER ATTACK PATTERNS

S.S. Kulikov, N.N. Murzinov

This article provides a description of the principles of construction and operation, as well as some architectural features of special software that can be used to analyze the security of information systems based on a database of patterns (patterns) of computer attacks typical for certain types of violators and their groups. The task of analyzing security is an important stage in information security work both in the formation of information security requirements and in assessing the effectiveness of measures already implemented. Due to the non-trivial, and to some extent even creative nature, the solution of this problem requires high qualifications from a specialist, significant time and material costs. As a result, an objective task arises to automate such activities. This paper describes an attempt to solve this problem on the basis of software development using data from open sources, summarizing the experience and qualifications of information security specialists from different countries.

Keywords: security analysis, information system, open data.

Submitted 21.09.2021

Information about the authors

Sergey S. Kulikov – Cand. Sc. (Technical), Assistant Professor, Voronezh State Technical University, e-mail: kulikov.serg@yandex.ru

Nikolay N. Murzinov – Student, Voronezh State Technical University, email: murzinov.nikolay@yandex.ru